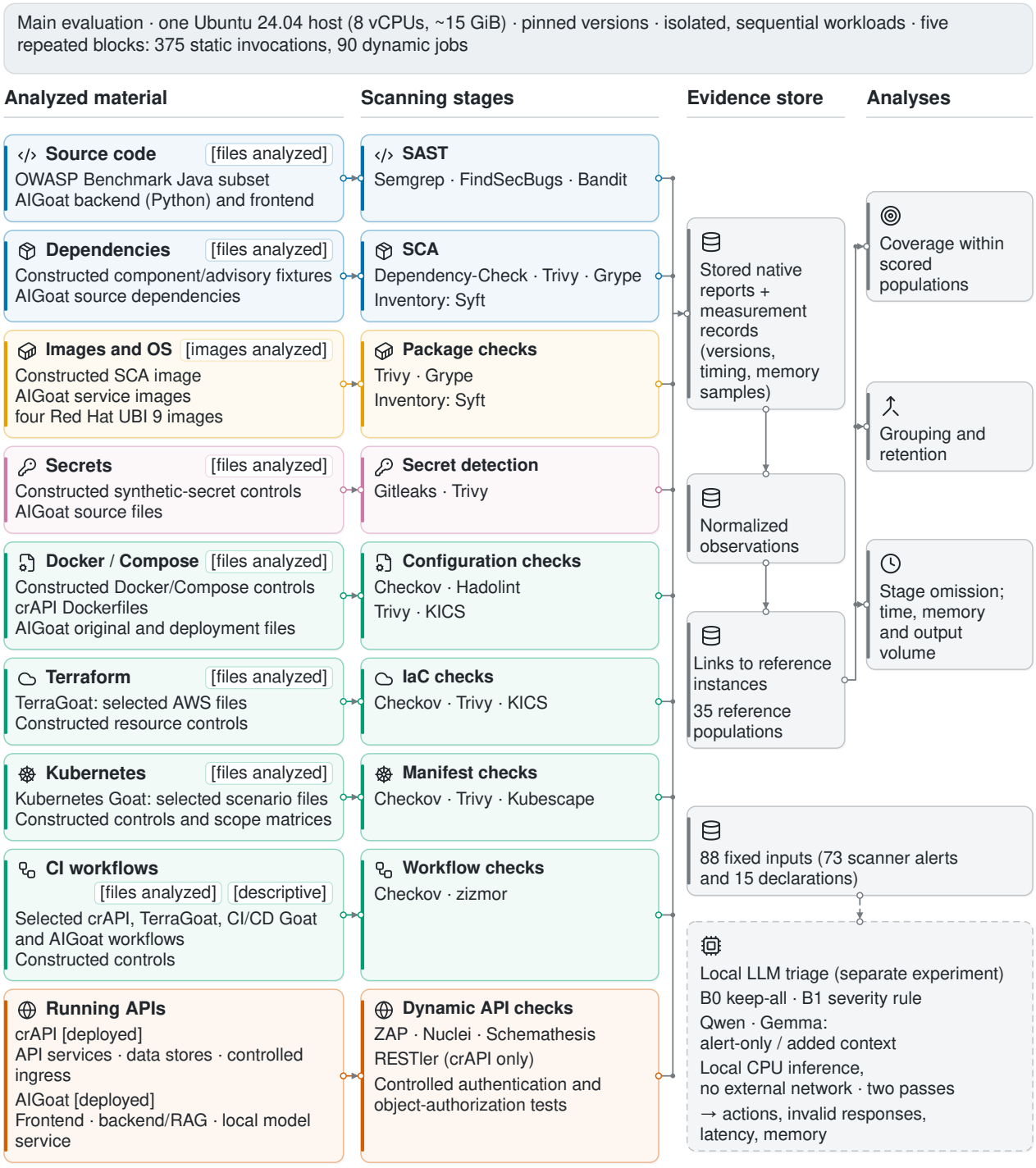
Main evaluation · one Ubuntu 24.04 host (8 vCPUs, ~15 GiB) · pinned versions · isolated, sequential workloads · five repeated blocks: 375 static invocations, 90 dynamic jobs
Analyzed material
Scanning stages
Evidence store
Analyses
Source code [files analyzed]
OWASP Benchmark Java subset
AIGoat backend (Python) and frontend
SAST
Semgrep · FindSecBugs · Bandit
Dependencies [files analyzed]
Constructed component/advisory fixtures
AIGoat source dependencies
SCA
Dependency-Check · Trivy · Grype
Inventory: Syft
Images and OS [images analyzed]
Constructed SCA image
AIGoat service images
four Red Hat UBI 9 images
Package checks
Trivy · Grype
Inventory: Syft
Secrets [files analyzed]
Constructed synthetic-secret controls
AIGoat source files
Secret detection
Gitleaks · Trivy
Docker / Compose [files analyzed]
Constructed Docker/Compose controls
crAPI Dockerfiles
AIGoat original and deployment files
Configuration checks
Checkov · Hadolint
Trivy · KICS
Terraform [files analyzed]
TerraGoat: selected AWS files
Constructed resource controls
IaC checks
Checkov · Trivy · KICS
Kubernetes [files analyzed]
Kubernetes Goat: selected scenario files
Constructed controls and scope matrices
Manifest checks
Checkov · Trivy · Kubescape
CI workflows [files analyzed] [descriptive]
Selected crAPI, TerraGoat, CI/CD Goat and AIGoat workflows
Constructed controls
Workflow checks
Checkov · zizmor
Running APIs
crAPI [deployed]
API services · data stores · controlled ingress
AIGoat [deployed]
Frontend · backend/RAG · local model service
Dynamic API checks
ZAP · Nuclei · Schemathesis
RESTler (crAPI only)
Controlled authentication and object-authorization tests
Stored native reports + measurement records (versions, timing, memory samples)
Normalized observations
Links to reference instances
35 reference populations
88 fixed inputs (73 scanner alerts and 15 declarations)
Local LLM triage (separate experiment)
B0 keep-all · B1 severity rule
Qwen · Gemma:
alert-only / added context
Local CPU inference,
no external network · two passes
→ actions, invalid responses, latency, memory
Coverage within scored populations
Grouping and retention
Stage omission; time, memory and output volume
solid line: data flow · dashed line: separate experiment on fixed inputs · badges: [files analyzed], [images analyzed], [deployed], [descriptive] = analyzed and measured, not scored